Home Network Security Posture

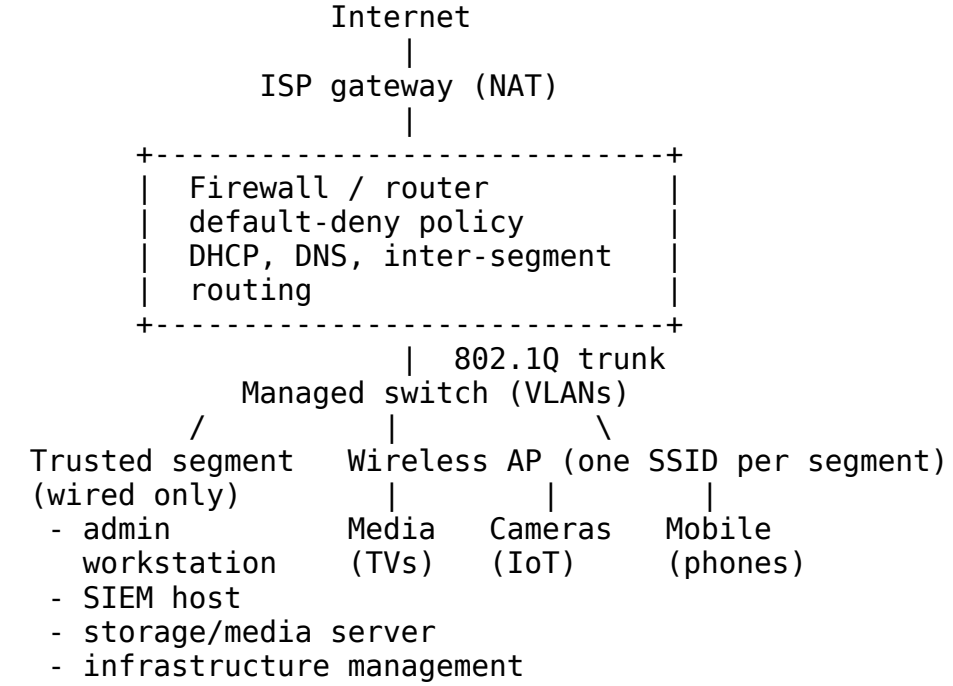
Jason Rochau

Summary

I designed, built, and operate a segmented home network with a self-hosted SIEM (security information and event management system). Devices are separated by how much they can be trusted, traffic between segments is denied unless explicitly allowed, and security events from the network's core systems flow into a central platform for detection and alerting.

This page documents the design, the security principles behind it, how it maps to recognized frameworks, and the engineering practices used to build and change it safely. Addresses, device identifiers, network and wireless names, and configuration details are deliberately withheld.

Architecture



Segment	Purpose	Access policy
Trusted	Administration, SIEM, storage, infrastructure management	Wired only; no wireless network maps to it. Management access restricted to the admin workstation.
Media	Smart TVs and streaming devices	Internet, DHCP, and DNS only. One narrowly scoped exception

Segment	Purpose	Access policy
		reaches the media server.
Cameras	IP cameras	Internet allowed (cloud-dependent devices); all lateral movement denied.
Mobile	Phones and tablets	Internet, DHCP, and DNS only; no access to other segments.

Design justification: the devices least under my control (TVs, cameras, phones) are the most likely to be compromised or to run vendor software I can't audit. Placing them in isolated segments means a compromised device can reach the internet but not the systems that hold data or control the network.

Security principles applied

Principle	How it's applied
Defense in depth	Controls are layered: segment isolation at the firewall, host firewalls on servers, container-level access rules on the SIEM, encryption at rest on the SIEM host, and detection on top of prevention.
Least privilege	Every segment starts from deny-all. Each allowance is a specific source, destination, and service. Management interfaces accept connections only from the admin workstation.
Default deny	Firewall input and forwarding policies drop anything not explicitly allowed. Container services are reachable only from an allow-list of approved hosts.
Attack surface reduction	Unneeded services are disabled, and SIEM components publish only the ports their agents need. The SIEM dashboard is bound to localhost and reached through an encrypted SSH tunnel instead of being exposed on the network.
Zero trust concepts	Network location alone doesn't grant access. Sensitive services check the specific source even inside the trusted

Principle	How it's applied
	segment.
Separation of duties between controls	Two independent rule sets must both pass before traffic reaches the SIEM containers, and neither depends on the other being correct.

Framework mapping — NIST CSF 2.0

The NIST Cybersecurity Framework 2.0 organizes security outcomes into six functions. The build maps to each one:

Function	What's in place
Govern	Written standing rules for every change; a master reference document regenerated from verified live state; documented decisions and closed items so settled questions aren't reopened.
Identify	Asset inventory of every host and infrastructure device with role, function, and access method; static DHCP reservations so devices keep stable identities; a known-devices list used for detection.
Protect	Segmentation and default-deny firewalling; restricted management access; hardened SIEM deployment (reduced exposed ports, vendor demo accounts removed, credentials rotated, secrets excluded from version control); signature-verified software packages at pinned versions.
Detect	Wazuh SIEM with agents on core systems; file integrity monitoring; a tiered alerting design (below); planned network intrusion detection.
Respond	Triage of alerts with a documented verdict and tuning plan for each false positive; planned per-severity notification channels.
Recover	Configuration backups for the firewall, switch, and servers; timestamped pre-change backups; an automatic rollback timer on risky

Function	What's in place
	firewall changes; a root filesystem backup with disk-encryption header export.

Framework mapping — CIS Critical Security Controls v8.1

CIS Control	Implementation
1 — Inventory and Control of Enterprise Assets	Documented asset inventory; DHCP reservations; known-devices list feeding detection.
3 — Data Protection	Encryption at rest on the SIEM host; secrets restricted by file permissions and kept out of version control.
4 — Secure Configuration	Hardened SIEM deployment tracked as version-controlled changes against the vendor baseline; unneeded services disabled.
5 / 6 — Account and Access Control Management	Default and demo accounts removed; unique credentials per service; management restricted to one workstation.
8 — Audit Log Management	Centralized log collection from core hosts; bounded log rotation; defined rules for which events become alerts.
11 — Data Recovery	Configuration and filesystem backups; documented rollback procedures.
12 — Network Infrastructure Management	VLAN segmentation; documented switch port and trunk design; configuration backups for network devices.
13 — Network Monitoring and Defense	Firewall drop telemetry and tiered alerting (in progress); network IDS on the internet-facing interface (planned).

Source: CIS Critical Security Controls list

Detection design

Platform: Wazuh (manager, indexer, and dashboard) running in Docker on a dedicated monitoring host, with endpoint agents on the firewall, the SIEM host, and the storage server.

Tiered alerting for blocked connection attempts. The goal is to see anything that tries to connect where it shouldn't, not only the patterns a vendor ruleset flags as critical. Each firewall drop is classified into a tier:

Tier	What it catches	Severity
Suppressed	Known-benign broadcast beacons from specific devices, matched on exact source, destination, and port	0 (not stored)
Every attempt	Any other blocked connection	3 (stored, searchable)
Management-port attempt	Blocked attempts against administrative or file-sharing services	≈6
Inter-segment attempt	Blocked traffic from an isolated segment toward another	7
Unknown device	A blocked connection from a trusted-segment device not on the known-devices list	10
Repeated — fast	Many attempts from one source in a short window (scan or flood)	10
Repeated — slow	A lower count from one source over a long window (patient scan)	10

Justifications:

- **Suppress by exact match only.** Allow-listing a whole device would hide a compromise of that device. Suppression is limited to the exact traffic proven benign.
- **Lists are data, not rules.** Suppression and known-device lists are lookup tables. Adding a device means editing a list, not rewriting detection logic.
- **Soak before paging.** Inter-segment alerts go to the dashboard only for several weeks. Traffic the soak proves benign (for example, device-discovery protocols) is added to the suppression list before these alerts are allowed to send notifications. This prevents alert fatigue.
- **Rate-limited logging with reconciliation.** Firewall logging is rate-limited per ingress segment so a flood can't overwhelm the log pipeline. Because a rate limit means a missing log line isn't proof that nothing happened, a scheduled heartbeat reports the true drop count every 15 minutes. The SIEM alerts when that count spikes, when the

heartbeat goes missing (a dead agent or tampering), and when counters reset unexpectedly (an unplanned rule set reload).

- **Tamper detection.** File integrity monitoring watches the firewall rule files on the hosts that enforce them.
- **Regression testing.** Real log lines are kept as a test corpus and replayed through the rule engine after every upgrade or rule change, to confirm detections still fire.

Engineering practices

- **Evidence first.** Documentation and memory are treated as hypotheses. Every assertion is verified against live system output before any action. This caught several places where the documentation had drifted from reality, each recorded in a corrections log.
- **Loaded is not the same as working.** A firewall rule being present doesn't prove it matches traffic. Rules are verified by watching their packet counters move.
- **Match on stable identifiers.** Rules key on names that don't change, such as fixed container bridge names, rather than names that can change with hardware or drivers.
- **Structured change control.** Every change follows: read the current config, take a timestamped backup, edit, syntax-check, apply, validate. Risky firewall changes also arm an automatic rollback timer that restores connectivity if the change locks out management access. The timer is disarmed only after a fresh session confirms access.
- **Supply-chain verification.** Agent packages are checked against the vendor's signed package index (GPG signature, then SHA-256 hash chain) before installation. All SIEM components are pinned to one version.
- **Secrets hygiene.** Credentials live in restricted files excluded from version control, are never pasted into chat or tickets, and are verified after rotation by confirming the new credential works and the old one is rejected.
- **False-positive triage.** Every unexpected alert is investigated to a root cause before it's tuned. Suppressions are scoped to the exact file paths or conditions proven benign, never to a whole rule.

Status and road map

Area	Status
Network segmentation and default-deny firewalling	Implemented
SIEM deployment and hardening	Implemented
Endpoint agents on firewall, SIEM host, and storage server	Implemented
Endpoint agents on admin workstation	In progress 1 of 2
Firewall drop telemetry and tiered alerting	In progress
DNS and DHCP event telemetry into the SIEM	Planned
Network intrusion detection	Planned

Area	Status
(Suricata) on the internet-facing interface	
Alert notification channels by severity	Planned
Retirement of the legacy logging stack	Planned

Scope of this document

This is a public summary. IP addressing, hardware identifiers, network and wireless names, host names, software versions, rule sets, and known open items are intentionally omitted. They're maintained in a private master reference.